

# Dependabot

## Mettre à jour ses dépendances automatiquement… sans casser son projet

**1 Détecter** **2 Proposer** **3 Vérifier** **4 Décider**

Cours DevOps · M1 SIGLIS · Madou DIAKAYETEBA & Mouhamed S. CAMARA · Octobre 2026

# Un code qui ne bouge pas, un risque qui grandit

**25**

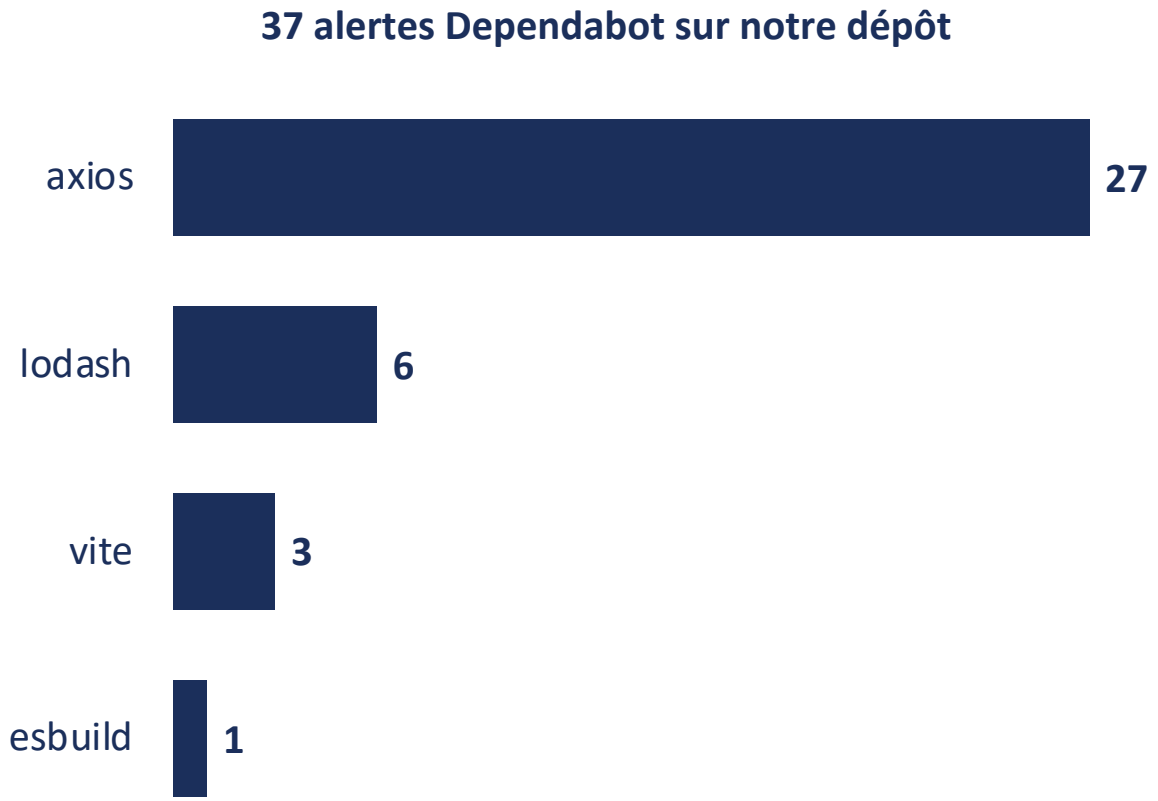
**failles connues sur axios 0.18.0**

dont 11 de gravité élevée

**2018**
publiée

**2019**
1re faille

**2026**
25 failles




Du 28 au 30/09/2026 · source : onglet Security du dépôt, GitHub Advisory Database

# Dependabot, c'est quoi ?

Un robot intégré à GitHub, gratuit, qui surveille vos dépendances et propose leurs mises à jour en pull requests.



## Alerts

Signale une dépendance vulnérable, sa gravité et la version qui corrige

sans configuration



## Security updates

Ouvre une PR vers une version qui corrige la faille

sans configuration

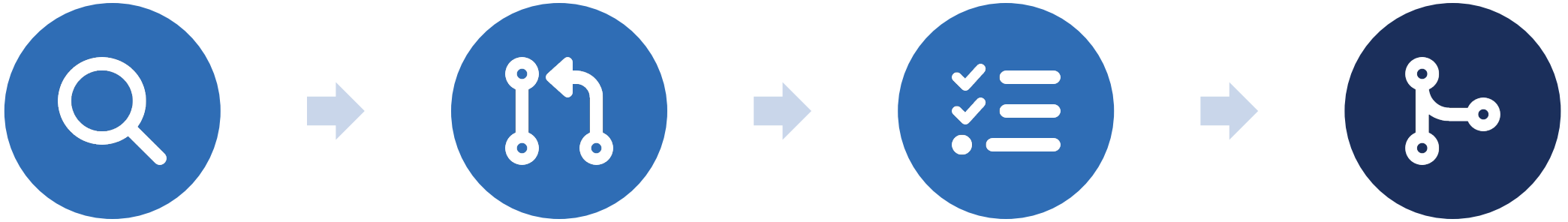


## Version updates

Ouvre des PR planifiées vers les dernières versions

`dependabot.yml`

# Le cycle : quatre étapes



## 1. Détecter

graphe de dépendances × Advisory Database

*Dependabot*

## 2. Proposer

ouvre une pull request

*Dependabot*

## 3. Vérifier

le CI installe, teste, compile

*Pipeline CI*

## 4. Décider

revue, merge, déploiement

*L'équipe*

**Dependabot propose. Le CI vérifie. L'humain décide.**

# Deux types de mises à jour



## Sécurité

- Déclenchée par une alerte
- Immédiate, sans limite de PR
- Une version qui corrige la faille

`PR n° 9 axios 0.18.0 → 0.33.0`



## Version

- Déclenchée par le calendrier (daily)
- 5 PR ouvertes au maximum
- La dernière version publiée

`PR n° 8 axios 0.34.0 → 1.20.0`

# Notre fichier dependabot.yml

.github/dependabot.yml

```yaml
version: 2
updates:
  - package-ecosystem: "npm"      # 1
    directory: "/"                # 2
    schedule:
      interval: "daily"           # 3
```

**1 Quoi**

npm : package.json + package-lock.json

**2 Où**

"/" : la racine du dépôt

**3 Quand**

daily : une vérification par jour

**Non écrit = valeur par défaut :** 5 PR de version max · pas de groupes · pas d'exclusion · 3 jours d'attente

# Démo en direct

`github.com/camanalyste-hub/demo-dependabotv1`

| | | | |
|---|---|---|---|
| 1 | **Détecter** | **Security › Dependabot alerts** | 37 alertes : axios, lodash, vite, esbuild |
| 2 | **Proposer** | **Pull requests** | n° 9 sécurité (0.33.0) vs n° 8 version (1.20.0) |
| 3 | **Vérifier** | **Checks d'une PR** | n° 1 vite groupé : **vert** vs n° 10 vite seul : **rouge** |
| 4 | **Décider** | **Actions › CI sur main** | n° 10 fusionnée en **rouge** : main cassé |

# Ce que notre dépôt prouve

28 septembre 2026, mise à jour de vite



**15:34**

**PR n° 1**

vite + plugin-react groupés

**CI vert**

**15:36**

**PR n° 10**

vite seul, 5 → 8

**CI rouge**

**15:37**

**Config simplifiée**

groupes retirés : n° 1 fermée

**15:45**

**PR n° 10 fusionnée**

malgré le rouge

**main cassé**

```
npm error ERESOLVE : @vitejs/plugin-react 4.7.0 n'accepte que vite 4 à 7
```

**La leçon :** protéger main (« Require status checks to pass ») et regrouper les paquets liés (groups).

# Ce qu'il faut retenir

1

## Détecte et propose

Il ne teste pas et ne fusionne rien seul.

2

## Deux modes

Sécurité : immédiat. Versions : planifié, via dependabot.yml.

3

## Indissociable du CI

Chaque PR est testée ; main doit être protégée.

4

## Se règle

groups, ignore, limite de PR, cooldown.

**Vigilance :** trop de PR · mises à jour cassantes, même de sécurité · alertes pas toujours pertinentes · versions piégées (axios piraté le 31/03/2026)

## Merci ! Des questions ?